Guion de pruebas con usuarios

Este guion orienta la sesión de prueba de SegSoft, una plataforma de análisis estático de seguridad y cumplimiento normativo de código fuente. Usted realizará un conjunto breve de tareas según el rol asignado y marcará cómo le fue en cada una. **Se evalúa la aplicación, no a la persona**: cualquier dificultad es información valiosa. Duración estimada: 30 minutos.

Datos de la sesión

Nombre o alias		**Fecha**	
Rol asignado	☐ Developer ☐ Auditor ☐ Security Admin		
Navegador		**Facilitador**	

Antes de empezar

Dirección de la aplicación	`https://segsoft-frontend.vercel.app`. Use Google Chrome o Microsoft Edge.
Cuenta de acceso	**Developer:** usted creará su propia cuenta en la tarea D-1. **Auditor y Security Admin:** el facilitador le entregará el usuario y la contraseña. Por seguridad, las contraseñas no se incluyen en este documento.
Proyectos de prueba	Tres versiones de una misma tienda en línea, en formato ZIP: `proyecto-vulnerable.zip`, `proyecto-intermedio.zip` y `proyecto-limpio.zip`. El facilitador se los entregará; también están en la carpeta `pruebas-usuarios` del repositorio `github.com/JEGH18/segsoft-docs`.

Cómo registrar cada tarea

- Lea la tarea completa antes de realizarla.
- Compare lo que observa en pantalla con la columna **Resultado esperado**.
- Marque **Sí** si la completó sin ayuda, **Con dificultad** si lo logró con dudas o con ayuda, y **No** si no pudo completarla.
- Si una tarea le toma más de tres minutos, márquela como **No** y continúe con la siguiente.
- Use el espacio de **Observaciones** para anotar lo que le resultó confuso o lo que esperaba que ocurriera.

En las páginas siguientes encontrará las tareas de cada rol. **Realice únicamente las de su rol.** Los textos entre comillas («») corresponden a botones, menús o mensajes tal como aparecen en la aplicación.

Al terminar

Cierre la sesión con el ícono ubicado arriba a la derecha y responda la **encuesta de satisfacción** cuyo enlace le compartirá el facilitador. Toma alrededor de 10 minutos.

Rol Developer

El Developer sube su proyecto, lo analiza con las políticas de seguridad y revisa los hallazgos para corregirlos. Usará el archivo `proyecto-vulnerable.zip`.

N.º	Tarea	Resultado esperado	Resultado
D-1	En la pantalla de inicio pulse «Crear cuenta». Elija un usuario (por ejemplo, sus iniciales seguidas de un número) y una contraseña que cumpla los requisitos indicados en el formulario. Pulse «Crear cuenta».	La aplicación lo lleva al Dashboard («Analiza tu proyecto») con la sesión iniciada.	☐ Sí ☐ Con dificultad ☐ No
Observaciones:			
D-2	En el Dashboard, con la opción «Subir archivo ZIP», cargue `proyecto-vulnerable.zip` y pulse «Subir y continuar a selección de políticas».	Se abre la pantalla «Selección de políticas».	☐ Sí ☐ Con dificultad ☐ No
Observaciones:			
D-3	Marque «Seleccionar todas (23)» y pulse «Guardar selección».	Aparece el mensaje «Selección guardada correctamente.» y el resumen indica 23 políticas.	☐ Sí ☐ Con dificultad ☐ No
Observaciones:			
D-4	Pulse «Iniciar análisis →» y espere el resultado.	Se abre «Resultados del análisis» con 8.85% de cumplimiento ponderado y 42 hallazgos en total.	☐ Sí ☐ Con dificultad ☐ No
Observaciones:			
D-5	Más abajo, en los filtros de hallazgos, filtre por la severidad «CRITICAL».	La tabla muestra solo los 17 hallazgos de severidad crítica.	☐ Sí ☐ Con dificultad ☐ No
Observaciones:			
D-6	Abra un hallazgo de la política «No almacenar secretos en código fuente».	Se muestran el archivo, la línea, el CWE y la evidencia, con el secreto oculto como `*****`.	☐ Sí ☐ Con dificultad ☐ No
Observaciones:			
D-7	Abra el menú «Reportes».	Un mensaje indica que los reportes están disponibles solo para los roles Auditor y Security Admin.	☐ Sí ☐ Con dificultad ☐ No
Observaciones:			

Rol Auditor

El Auditor analiza proyectos y genera los reportes de cumplimiento que sirven como evidencia. Usará el archivo `proyecto-intermedio.zip` y la cuenta entregada por el facilitador.

N.º	Tarea	Resultado esperado	Resultado
A-1	Inicie sesión con el usuario y la contraseña entregados por el facilitador.	Se abre el Dashboard; arriba a la derecha aparece su usuario con el rol AUDITOR.	☐ Sí ☐ Con dificultad ☐ No
Observaciones:			
A-2	Cargue `proyecto-intermedio.zip`, marque «Seleccionar todas (23)», pulse «Guardar selección» y luego «Iniciar análisis →».	«Resultados del análisis» muestra 88.68% de cumplimiento ponderado y 5 hallazgos de severidad MEDIUM.	☐ Sí ☐ Con dificultad ☐ No
Observaciones:			
A-3	Pulse «Generar reporte».	Se abre el «Reporte de cumplimiento» en la «Vista técnica».	☐ Sí ☐ Con dificultad ☐ No
Observaciones:			
A-4	Cambie a la «Vista ejecutiva» y revise su contenido.	Se mantienen los indicadores, las recomendaciones y la cobertura; desaparecen la tabla de políticas y los hallazgos detallados.	☐ Sí ☐ Con dificultad ☐ No
Observaciones:			
A-5	Pulse «Descargar PDF» y, después, «Descargar SARIF». Abra el PDF.	Se descargan los archivos `segsoft-report-….pdf` y `….sarif`. El PDF tiene portada, índice y número de página.	☐ Sí ☐ Con dificultad ☐ No
Observaciones:			
A-6	Abra el menú «Reportes» y ubique el reporte que generó.	El reporte aparece en la lista con integridad «Verificada».	☐ Sí ☐ Con dificultad ☐ No
Observaciones:			

Rol Security Admin

El Security Admin administra el banco de políticas de seguridad y los Policy Sets. Usará la cuenta entregada por el facilitador. Incluya sus iniciales en los nombres que cree, para distinguirlos de los de otros participantes.

N.º	Tarea	Resultado esperado	Resultado
S-1	Inicie sesión y abra el menú «Policies».	Se abre el «Banco de Políticas de Seguridad» con el botón «+ Nueva política».	☐ Sí ☐ Con dificultad ☐ No
Observaciones:			
S-2	Pulse «+ Nueva política» y registre una política: un nombre con sus iniciales, una descripción de al menos 20 caracteres, el marco normativo «Personalizado», una categoría y el control `TEAM-XSS-01`.	La política queda registrada y aparece en el banco con estado «Activa».	☐ Sí ☐ Con dificultad ☐ No
Observaciones:			
S-3	Abra su política, cambie el «Peso de criticidad» a 70 y pulse «Guardar cambios».	El cambio se guarda y queda registrado en el «Historial de cambios».	☐ Sí ☐ Con dificultad ☐ No
Observaciones:			
S-4	En la misma política pulse «+ Añadir regla», elija el tipo «Patrón Regex», escriba el patrón `password\s*=` y pulse «Guardar regla».	La regla aparece en la tabla «Reglas técnicas» de la política.	☐ Sí ☐ Con dificultad ☐ No
Observaciones:			
S-5	Abra «Policy Sets», pulse «+ Nuevo Policy Set», escriba un nombre con sus iniciales, marque tres políticas del banco distintas de la suya y pulse «Crear Policy Set».	Se abre el detalle del Policy Set con «3 políticas · versión 1».	☐ Sí ☐ Con dificultad ☐ No
Observaciones:			
S-6	Vuelva a su política, pulse «Archivar» y confirme la acción.	La política queda en estado «Archivada» y ya no se ofrece al seleccionar políticas para un análisis.	☐ Sí ☐ Con dificultad ☐ No
Observaciones:			

Notas para el facilitador

Esta página no se entrega a los participantes.

Antes de la sesión

- **Encender el servidor.** En el portal de Azure: Virtual machines → `segsoft` → «Start». Esperar unos dos minutos. El servidor se apaga solo a las 2:00 a. m.; al terminar la jornada puede detenerse con «Stop» para ahorrar créditos.
- **Verificar el acceso.** `https://segsoft-frontend.vercel.app` debe mostrar la pantalla «Bienvenido». Si el inicio de sesión falla con un error de red, el servidor aún no ha arrancado.
- **Cuentas.** Los participantes Developer crean su cuenta en la tarea D-1. Para Auditor y Security Admin, entregue el usuario y la contraseña en privado. Puede consultarlos con `ssh Segsoft@20.168.55.230 'grep SEGSOFT_ACCOUNTS /opt/segsoft/segsoft-backend/deploy/.env'`. Tras cinco contraseñas incorrectas, la cuenta se bloquea durante 30 minutos.
- **Material.** Tenga a mano los tres proyectos ZIP y el enlace de la encuesta.

Valores esperados

Proyecto	Cumplimiento ponderado	Hallazgos	Políticas que cumplen
`proyecto-vulnerable.zip`	8.85%	42 (17 críticos)	2 de 23
`proyecto-intermedio.zip`	88.68%	5 (todos de severidad media)	20 de 23
`proyecto-limpio.zip`	100%	0	23 de 23

Valores con las 23 políticas activas. En el reporte y en la lista de reportes los porcentajes aparecen con un decimal (por ejemplo, 88,7 %).

Comportamientos conocidos (no son fallas)

- En «Resultados del análisis», el estado de cada política aparece en inglés (COMPLIANT, NON_COMPLIANT, REQUIRES_REVIEW); en el reporte aparece en español.
- Toda cuenta creada desde «Crear cuenta» tiene el rol Developer. Los roles Auditor y Security Admin solo se asignan desde el servidor.
- Un participante Developer solo puede abrir los análisis que él mismo realizó.

Después de la sesión

- Las políticas creadas por los participantes quedan archivadas en la tarea S-6. Los Policy Sets de prueba pueden archivarse desde su detalle.
- Recoja las hojas del guion y verifique que cada participante haya enviado la encuesta.